

～ AIに任せる作業にも、 外へ出したくない情報がある。～

非公開のコードや資料を使って、AIに開発を手伝ってもらいたい。その一方で、作業中に使った情報を、外部サービスへ勝手に送ってほしくはありません。ToolUseProxyは、AIによる情報の持ち出しを、ツール操作の実行前に検知・停止する研究開発プロジェクトです。

ここでいう「ツール」は、AIが作業するための機能。ファイルを読む、コマンドを実行する、外部サービスへ送信するなどの機能を指し、その呼び出しを「ToolCall」といいます。

研究の問い

必要な作業を止めずに、
守るべき情報の送信を止められるか。

「読む必要がある」と「送ってよい」は違う

たとえば、非公開コードの不具合をAIに調べてもらうとき。コードを読むことは必要でも、調査のための外部リクエストに、その中身まで含めてよいとは限りません。作業を許可したことで、その途中で扱う情報の外部送信を許可したことは、分けて考える必要があります。

「この資料を送らないで」と依頼するだけでなく、AIが実際に選んだ操作を、実行前に確かめる方法を考えています。

別のファイルに移った情報も追いたい

元のファイルをそのまま送る場合だけが問題ではありません。資料の一部を別のファイルに書き出したり、ツールへの入力に含めたりすると、ファイル名だけを見ても情報の持ち出しは分かりません。

そこで、送信する内容の照合に加え、観測した操作から情報の由来をたどります。内容が一致したという事実と、同じ情報に由来するというモデルの推定を区別して扱います。

止めすぎると、任せたい作業も進まない

保護情報の見逃しを減らすだけでは十分ではありません。公開してよい資料や、保護情報と無関係なファイルの送信まで止まると、利用者は作業を続けられません。

止めるべき送信を止められるか。同時に、止める必要のない操作を通せるか。この両方を確かめます。判定未完了による実行保留も、流出を検出した遮断とは分けて扱い、不要な待ち時間を減らします。

動く試作で、判定の根拠を確かめる

ToolUseProxyでは、操作の実行前に検査を挟み、取得できた入力・出力と判定を記録します。止まった結果だけでなく、何を見て止めたのかを確認できるようにしています。

任意の言い換えや暗号化まで見抜ける段階ではありません。観測できる範囲とモデルによる推定の限界を明らかにし、見逃しと誤停止を減らすことを目指しています。

送信内容と、その情報の由来を調べる。

判定では、操作の入力・出力や必要な資料の内容を、Codex経由でモデル提供元へ送ります。保護情報が含まれる場合もあるため、初期設定時に同意を確認します。操作の記録はローカルに保存します。

① 保護対象を登録 → ② 送信内容を確認 → ③ 一致と由来を検査 → ④ 実行可否を判定

1 守るファイルを選んで登録する

Pluginを導入し、Codexで「このプロジェクトでToolUseProxyを使いたい」と依頼します。データの扱いに同意して初期設定を行うと、サイドパネルにログ画面を開きます。

続けて、守りたいファイルを指定します。登録はファイル全体単位で、元のファイルは変更しません。操作の記録は初期設定した時点から始まり、それ以前の履歴は取り込みません。

3 保護情報との一致と由来を調べる

モデルが操作の入力・出力から情報の依存関係を推定し、グラフに記録します。外部送信時にその経路をたどり、現在の保護対象につながるかを機械的に調べます。送信内容と保護情報の直接照合も併用します。

たとえば、資料を読んで手順書を作り、手順書だけを送る場合。手順書そのものを登録していなくても、元の資料への経路が見つかれば送信を止めます。モデルによる推定には、見逃しや誤検出が残ります。

2 外部へ送る操作と内容を確認める

ツールを呼び出す直前に、Hookという通知の仕組みを通して入力を受け取ります。入力やツールの仕様に明示された外部送信かどうかを、モデルで判定します。

ファイル名だけが指定されたアップロードなどでは、対応する送信形式に応じて対象の内容を取り出します。Gitの送信では、送信対象のコミットに含まれる内容も調べます。

4 判定に従い、送信の実行を制御する

保護内容との一致、または秘密情報源への経路が見つかった送信を止めます。判定中は実行を保留して再試行し、完了できない場合は保留が続きます。これは流出を検出した遮断とは区別します。

ログは自動更新され、入力・出力や判定理由を確認できます。プロジェクト・セッションでの絞り込みや、ブロック判定だけの表示もできます。



公開コード・導入手順

github.com/mani1261790/ToolUseProxy

試せる環境と、保護できる範囲

macOS・Linux、Python 3.11 / 3.12、Plugin対応のCodexで使う研究用アルファ版です。最初は機密情報を含まない資料で試してください。導入手順はQRから確認できます。

Hookに届かない操作や、入力に現れないスクリプト内部・ローカルサービス経由の通信は検査対象外です。AIモデルとの通信全体は保護しません。ログにも機密情報が残る場合があり、共有前に確認が必要です。